

Cybersecurity & Operational Resilience

Maturity Assessment

Risk & Compliance | ME-RC-2024-0041 | Hashemite Kingdom of Jordan | February 2024

Executive Summary

EY Middle East was engaged to conduct a Cybersecurity and Operational Resilience Maturity Assessment for a major Jordanian telecommunications operator. The assessment was commissioned following a series of sector-wide cyber incidents in the MENA region and the Telecommunications Regulatory Commission (TRC) Jordan's new cybersecurity guidelines issued in late 2023.

The assessment evaluated 12 cybersecurity domains against the NIST Cybersecurity Framework (CSF 2.0), ISO 27001:2022, and TRC Jordan specific requirements. Additionally, operational resilience was assessed across 8 critical business services. Overall cybersecurity maturity was rated at Level 2.3 out of 5, with operational resilience at Level 2.1 - both below the TRC minimum target of Level 3.0 by 2025.

Assessment Scope

- NIST CSF 2.0 gap assessment across all 6 functions (Govern, Identify, Protect, Detect, Respond, Recover)
- Penetration testing: external perimeter, internal network, and web application testing
- Social engineering assessment: phishing simulation targeting 500 staff
- Operational Resilience: recovery time and recovery point objectives for 8 critical services
- Third-party cyber risk: assessment of top 15 suppliers by criticality
- Security Operations Centre (SOC) effectiveness review

Maturity Assessment by Domain

Cybersecurity Domain	Current Maturity	Target	Priority	Key Gap
Identity & Access Management	2.5	4.0	High	PAM solution absent; MFA not on all critical systems
Network Security	2.8	3.5	Medium	Micro-segmentation incomplete; legacy firewall rules
Endpoint Protection	2.0	3.5	High	EDR deployed on 61% of endpoints; no mobile MDM
Security Monitoring (SIEM/SOC)	1.8	4.0	Critical	SIEM covers 42% of log sources; SOC tier 2 understaffed
Vulnerability Management	2.2	3.5	High	Patch cycle 87 days average vs target 30 days
Incident Response	2.0	3.5	High	IR plan not tested; no third-party IR retainer
Data Loss Prevention	1.5	3.0	High	DLP tool not deployed; data classification incomplete
Third-Party Risk Management	1.8	3.0	High	No cyber risk questionnaire for 73% of suppliers
Security Awareness Training	2.5	3.5	Medium	Annual training only; 38% phishing click rate
Governance & Policy	3.0	4.0	Medium	Policies current but Board cyber reporting absent

Critical Vulnerabilities Identified

Penetration Testing Results: External penetration testing identified 3 critical and 7 high severity vulnerabilities. Most concerning: an unauthenticated API endpoint in the customer self-service portal exposing subscriber data for approximately 240,000 customers. This has been remediated as an emergency action following disclosure.

Phishing Simulation: 38% of staff clicked the simulated phishing link, and 22% entered credentials - both significantly above the industry benchmark of <10% and <5% respectively. The Finance and Customer Service departments showed the highest susceptibility rates.

Operational Resilience: Recovery Time Objective testing revealed that 5 of 8 critical services would exceed their agreed RTO in a major incident scenario. The core billing platform has a 72-hour tested recovery time against a 4-hour RTO commitment in the business continuity plan.

Remediation Priorities (90-Day Plan)

Initiative	Priority	Investment (JOD)	Timeline	Owner
Deploy EDR to remaining 39% of endpoints	Critical	85	30 days	CISO/IT
Expand SIEM log source coverage to 90%	Critical	120	60 days	SOC Manager
Implement PAM for privileged accounts	Critical	95	60 days	IT/CISO
Conduct IR tabletop exercise and retainer	High	35	30 days	CISO
Launch monthly phishing training programme	High	25	30 days	HR/Security
Deploy DLP and complete data classification	High	110	90 days	CISO/IT
Patch all critical/high vulnerabilities	Critical	Internal	30 days	IT Operations
Initiate billing platform DR upgrade	High	320	90 days	CTO/IT

TRC Compliance Gap Summary

Against TRC Jordan Cybersecurity Guidelines (2023), the operator is non-compliant in 7 of 18 mandatory requirements. Key non-compliances include: absence of a documented cyber risk register, lack of 24/7 SOC capability, and no annual third-party cyber audit. EY recommends engaging TRC proactively with a remediation plan within 45 days to mitigate regulatory sanction risk.